

PENETRATION TESTING REPORT

OWASP Juice Shop

Prepared by: Adhithyan

Date: 13 May 2026

Target: localhost:3000

Tools: Kali Linux 2025.2, VirtualBox

VULNERABILITY 1: SQL INJECTION

OWASP: A03:2021 – Injection

Severity: Critical

URL: localhost:3000/#/login

Time: 13-05-2026, 14:22

What I Did:

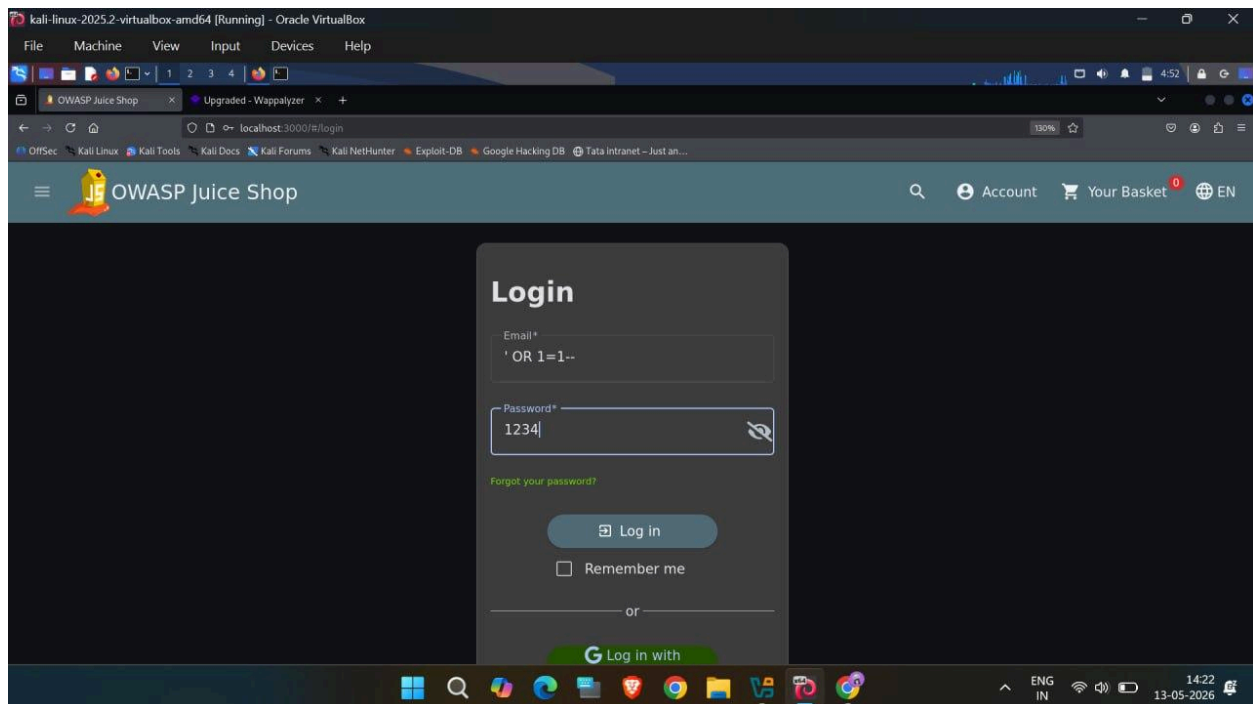
Entered ' OR 1=1-- in the email field. The application bypassed authentication and logged me in as administrator without a valid password.

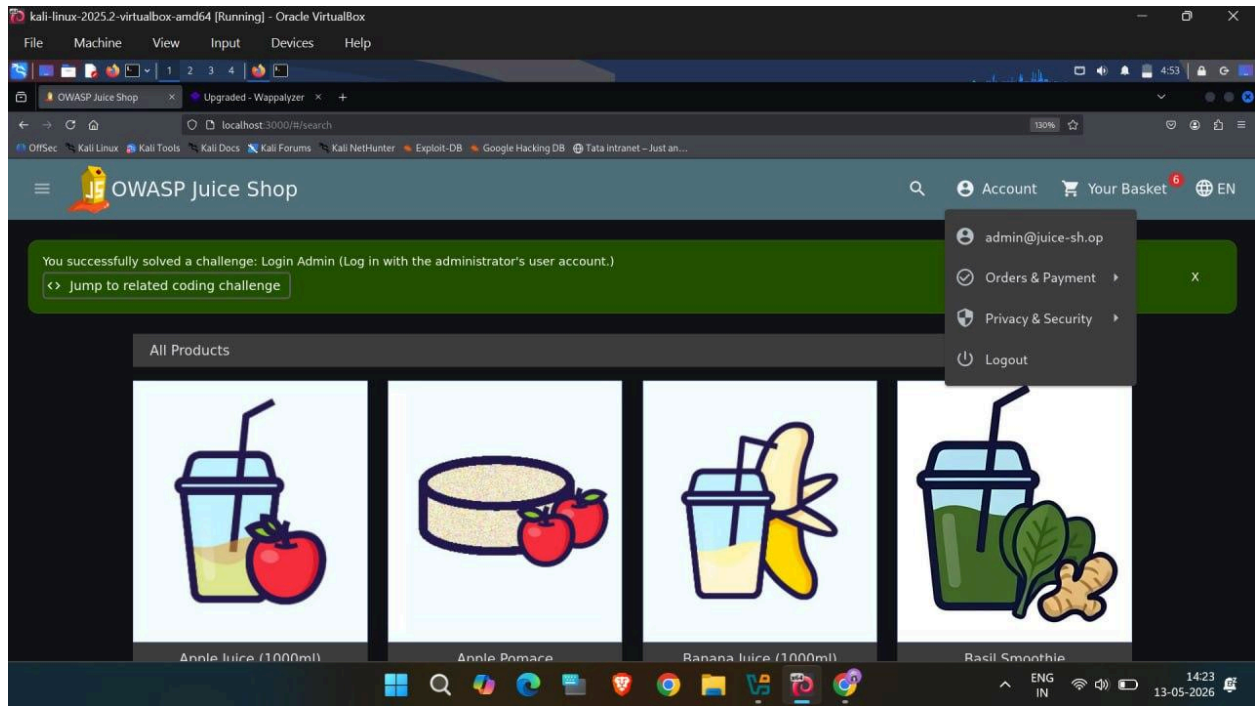
Impact:

Any attacker can gain full admin access without credentials, leading to complete account takeover.

Fix:

Use parameterized queries and validate all user inputs.





VULNERABILITY 2: CROSS-SITE SCRIPTING (XSS)

OWASP: A03:2021 – Injection

Severity: Critical

URL: localhost:3000/#/search

Time: 13-05-2026, 14:28

What I Did:

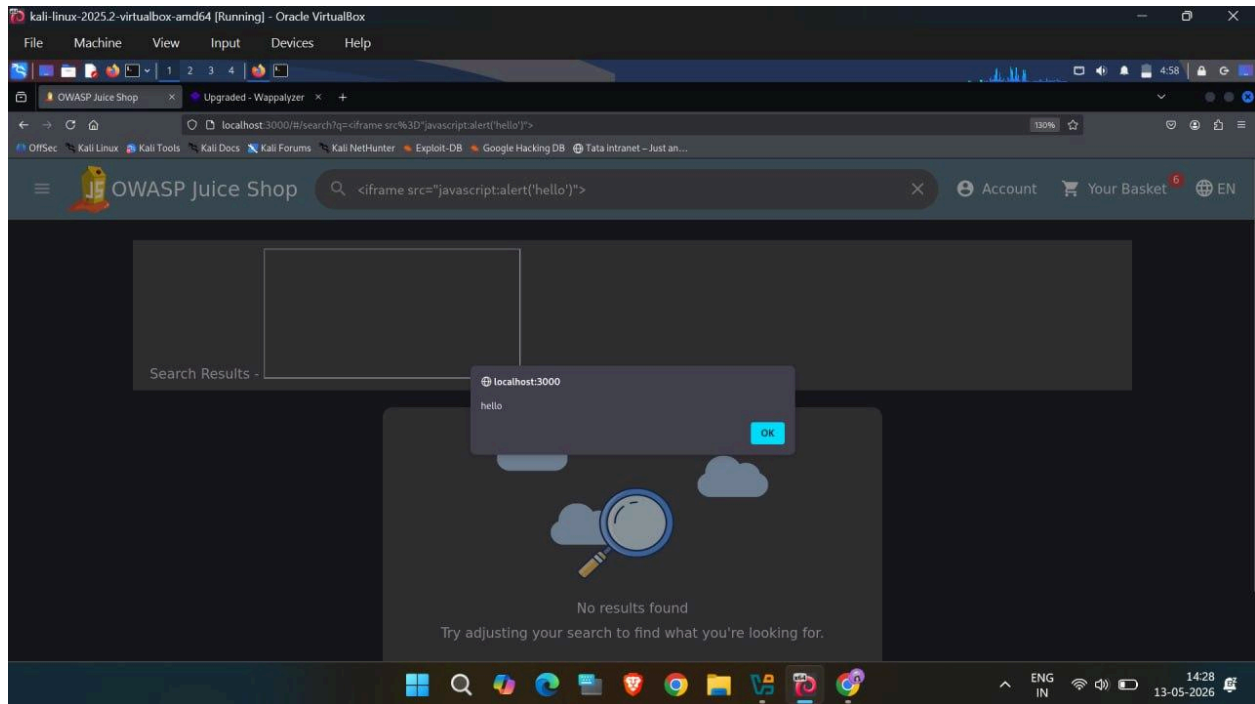
Entered `<iframe src="javascript:alert('hello')">` in the search bar. A JavaScript alert box executed in the browser.

Impact:

Attackers can steal cookies, hijack sessions, or redirect users to malicious sites.

Fix:

Encode all user output. Implement Content Security Policy (CSP).



VULNERABILITY 3: SENSITIVE DATA EXPOSURE

OWASP: A02:2021 – Cryptographic Failures

Severity: Critical

URL: localhost:3000/ftp/acquisitions.md

Time: 13-05-2026, 14:45

What I Did:

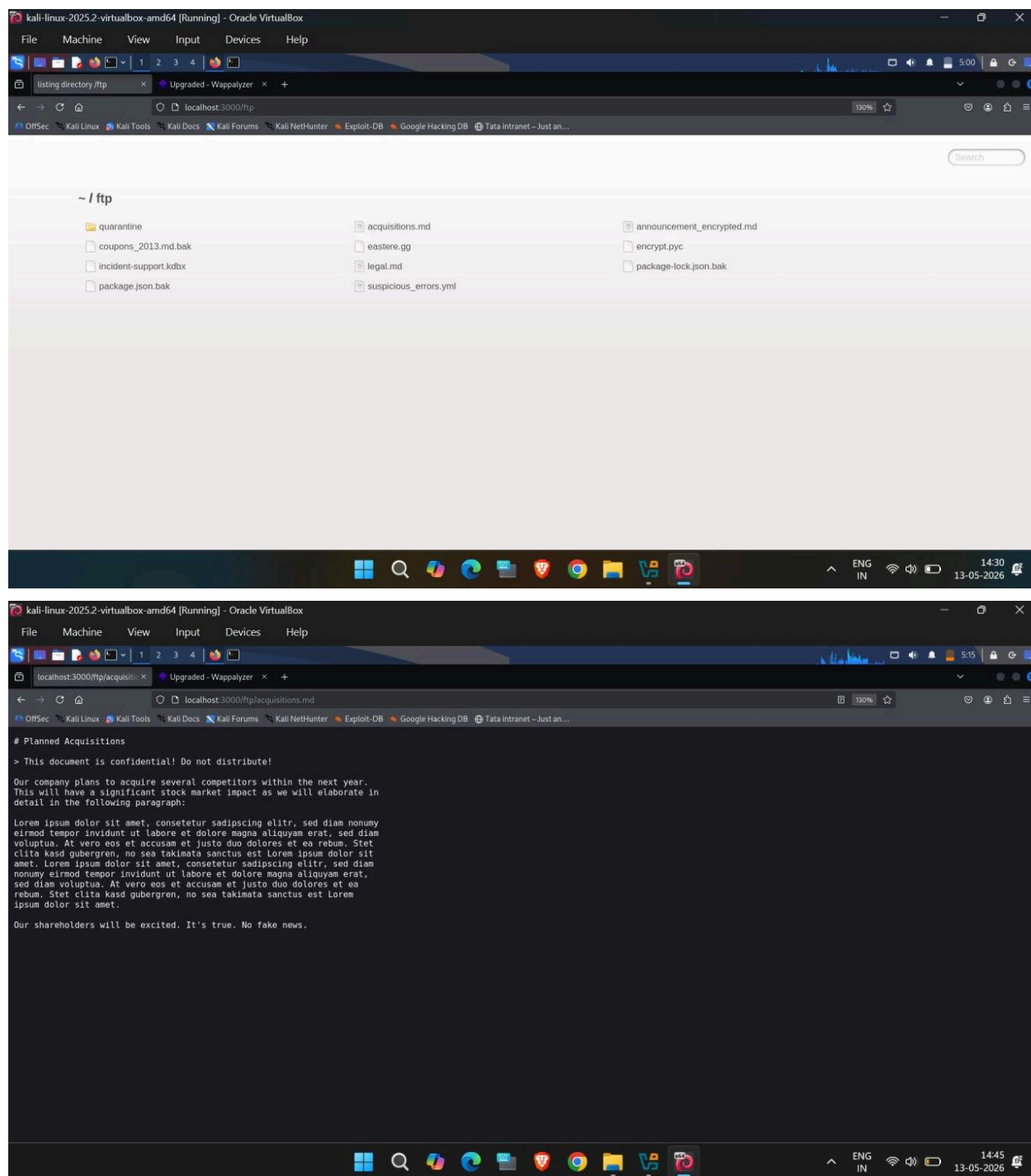
Accessed the /ftp/ directory without any login. Found and opened a confidential document marked "Do not distribute" containing planned company acquisitions.

Impact:

Confidential business data is exposed to anyone on the internet — violates GDPR and data protection laws.

Fix:

Never store sensitive files in public directories. Restrict /ftp/ with authentication.



VULNERABILITY 4: BROKEN ACCESS CONTROL

OWASP: A01:2021 – Broken Access Control

Severity: Critical

URL: localhost:3000/#/administration

Time: 13-05-2026, 14:33

What I Did:

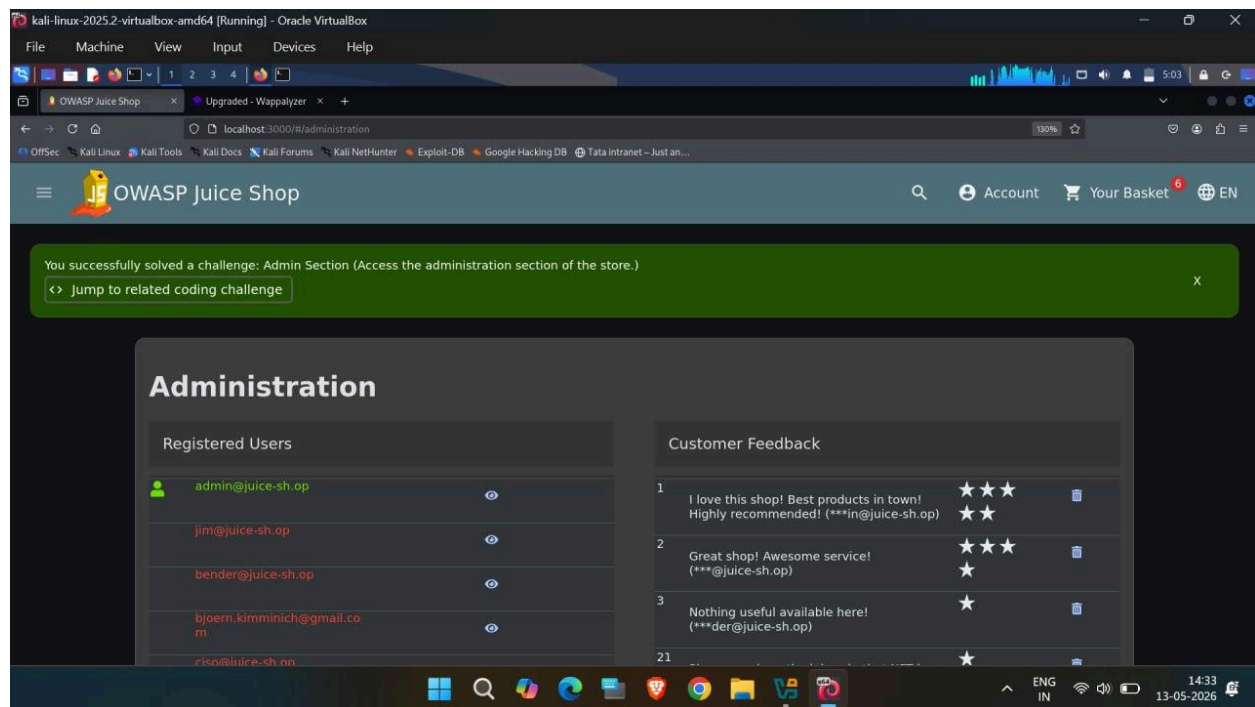
Directly navigated to the admin panel URL without admin privileges. The full administration page loaded showing all registered users and customer data.

Impact:

Any user can access the admin panel and view or manipulate all user accounts — complete privilege escalation.

Fix:

Implement server-side role-based access control (RBAC). Never rely on client-side route protection alone.



VULNERABILITY 5: SECURITY MISCONFIGURATION

OWASP: A05:2021 – Security Misconfiguration

Severity: High

URL: localhost:3000/api-docs/

Time: 13-05-2026, 14:36

What I Did:

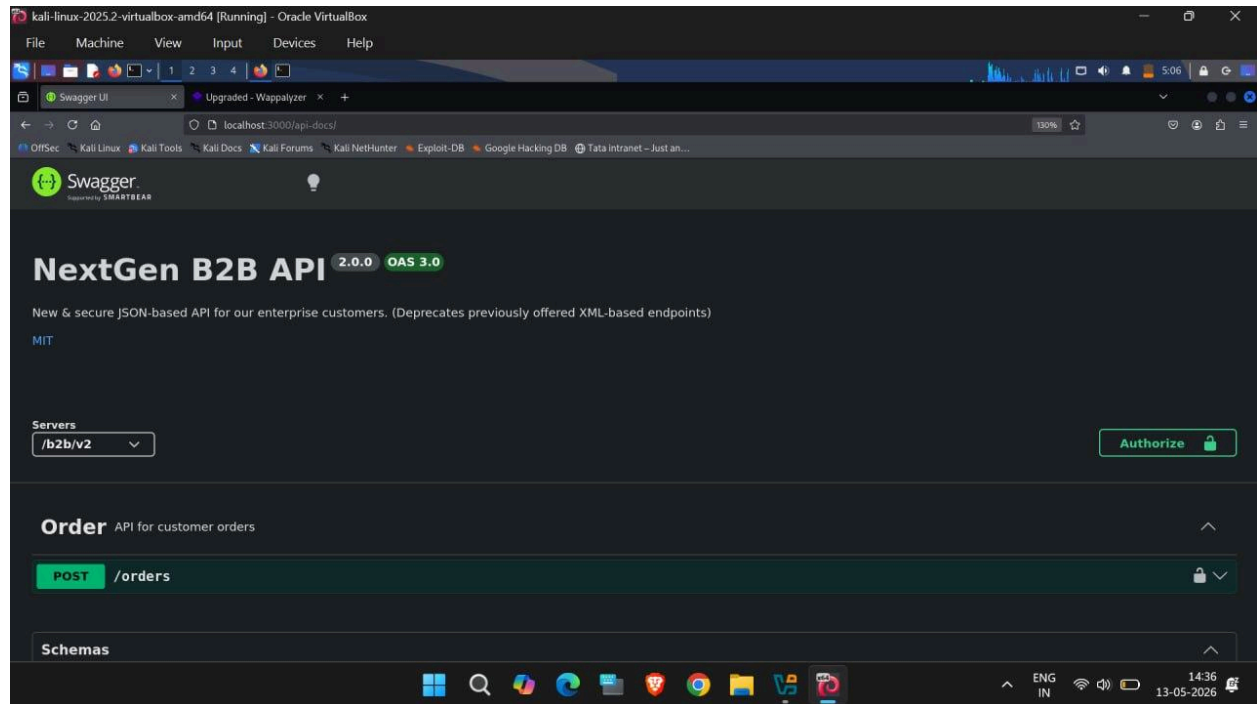
Accessed the Swagger API documentation page without authentication. All internal API endpoints, schemas, and request structures were fully visible.

Impact:

Gives attackers a complete map of the application's attack surface, drastically reducing time needed to find and exploit vulnerabilities.

Fix:

Disable API docs in production. Restrict access to authenticated users only.



CONCLUSION

Five critical vulnerabilities were identified and exploited in OWASP Juice Shop. The most severe finding is SQL Injection which allows complete admin takeover. Immediate remediation is recommended starting with parameterized queries and proper access control implementation.

Tested by: Adhithyan AK

GitHub: github.com/adhithyan4k

Date: 13 May 2026